



UNIT 01

PREVENTION AND AWARENESS





- **General principles in cyber security**
- **Workplace protection regulations**
- **Training and awareness plan in terms of cyber security**
- **Training and awareness materials**
- **Internal compliance audits in the field of prevention**



Cybernetics

The Cybernetics is the science that studies the information flows of a system and how he uses them to control himself

Their Key concepts are **stimulus capture, information processing, elaboration of answers, recursion, feedback** and, in general, everything anything that is related to the **self-control** of a system of any type.

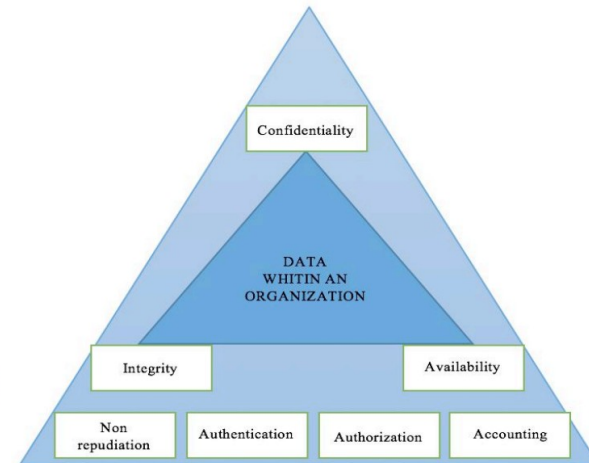
This science applies in many disciplines, from Physics to Medicine, but in Nowadays it is mainly used in Systems Theory and especially in Systems Computer scientists

Programming
Computing
Robotics
Regulation systems
Communication system



General principles in cyber security

Confidentiality
Integrity
Availability



Extended CIA model

**Information
security VS
IT security**

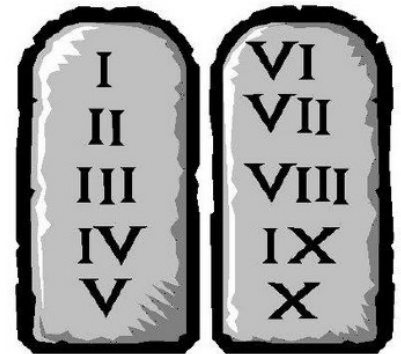


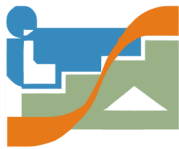


General principles in cyber security

The National Cryptological Center (CCN) publishes and updates a report detailing both the Principles General Cybersecurity Matters, such as recommendations, fundamental measures and good practices to raise awareness and facilitate use Insurance of Information Technologies and Communication

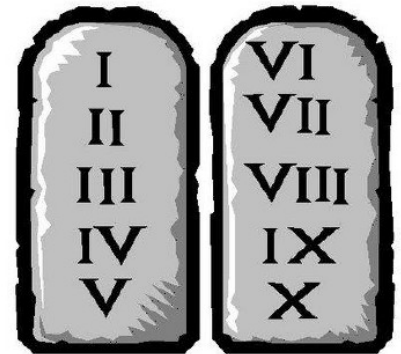
This report includes a Basic Decalogue of Cybersecurity that summarizes its content in ten general principles.





General principles in cyber security

- 1) The cybersecurity culture, employee awareness
- 2) You should not open any link or download any file attached from of an email that presents any indication or pattern outside of what usual.
- 3) Use security software
- 4) Limit the surface area of exposure to threats
- 5) Encrypt sensitive information
- 6) Use passwords adapted to the functionality
- 7) Perform a secure erase of information
- 8) Make regular backups
- 9) Keep applications and operating system up to date
- 10) Regularly review applied security settings





Best practices for achieving the General Principles in cyber security

Access control policy closed by default
Least Privileges Policy
Segregation of functions
Defense in depth
Training in cyber security
Cyber security audits

→ The collaboration of higher levels of the organization will be necessary

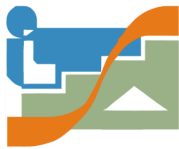


Classical Security

It is important to consider that classical security has as basic pillars, Prevention and Awareness of the people, principles that apply directly to the business environment

In this unit, we will reflect on how to implement **Prevention and Awareness Plans** that help us strengthen the resistance of a company against computer attacks of any kind.

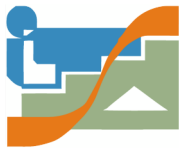
→ **The collaboration of higher levels of the organization will be necessary**



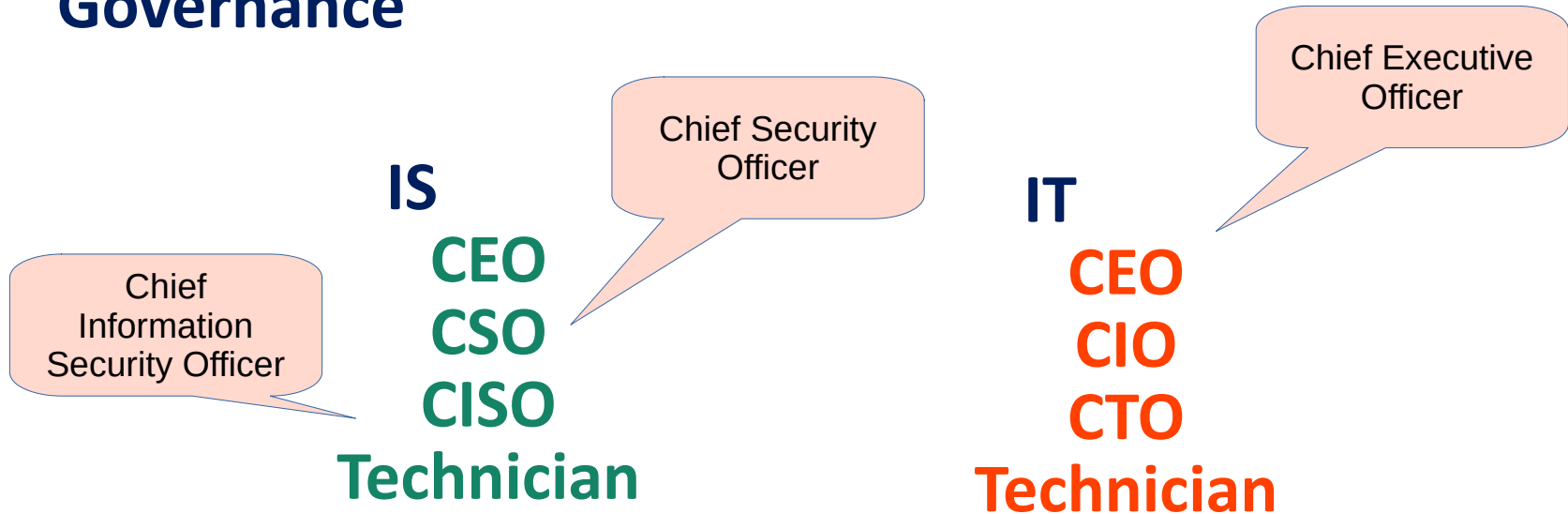
The Three Pragmatic Rules of Cybersecurity according to AC (Agile Corporation)

**Prevention
Awareness**

RESPONSE



Governance



<https://www.incibe.es/empresas/blog/roles-en-ciberseguridad-desde-el-ceo-los-usuarios-finales>

→ **The collaboration of higher levels of the organization will be necessary**



Commitment (Compromís)

Define the general principles of the organization regarding Cybersecurity.

These must be **known** and **supported** by **company management**

Organization <---> Cybersecurity



communicate



--- Convey this commitment to the organization ---



Commitment (Compromís)

Define the general principles of the organization regarding Cybersecurity.

These must be **known** and **supported** by **company management**



--- Convey this commitment to the organization ---



Cybersecurity culture

Organization <---> Organizational chart



<https://www.incibe.es/protege-tu-empresa/que-te-interesa/desarrollar-cultura-en-seguridad>

**--- Convey this commitment to the organization ---
at all levels !!**



Cybersecurity culture

International Standard. Certification



--- Convey this commitment to the organization ---
at all levels !!



CONCEPTS

Vulnerability

Threat

Attack

Exploitation of the attack

Protection (active, passive)

Protection (physical, logical)

Cyber security policies

Cyber security mechanisms

Cyber security standards



CONCEPTS

Level of Danger



Impact Level





¿What to protect ?

Elements to protect

- **Software**
- **Hardware**
- **Data** ← The most important and difficult to recover
- **Communications**
- **Human Factor**

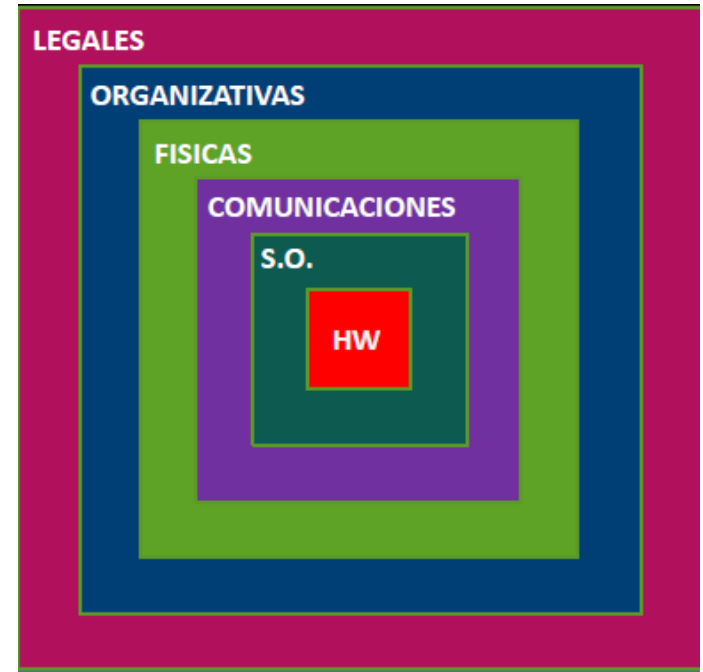


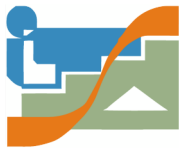
atac-informatic-greu-a-la-uab

caida-de-facebook

robo 35mill\$ deepfake

Deep
Levels





¿A little practice? ?

→ Crunch and John the Ripper





- General principles in cyber security
- **Workplace protection regulations**
- Training and awareness plan in terms of cyber security
- Training and awareness materials
- Internal compliance audits in the field of prevention



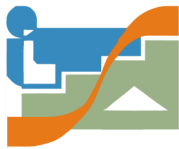
Workplace protection regulations

Excerpt from INCIBE infographic

- Destroy information using secure mechanisms
- Maintain the confidentiality of your company information
- Do not post or share passwords
- Do not keep passwords in visible places
- Use strong passwords
- Keep your operating system and antivirus up to date
- Lock the session when you are absent from the workplace
- Make appropriate use of removable devices
- You do not alter the configuration of your corporate team
- Control the use of personal storage devices

<https://www.incibe.es/protege-tu-empresa/que-te-interesa/proteccion-puesto-trabajo>

<https://www.incibe.es/empresas/blog/actualizate-ciberseguridad-el-nuevo-kit-conciencia>
cion



Workplace protection (techniques)

Excerpt from INCIBE infographic

- Workplace protection technique
- Prevention technique respects the rules
- Defense technique against information leaks
- Defense technique against social engineering attacks





Workplace protection (policies)

Excerpt from INCIBE infographic

- Policies for the businessman
- Policies for technical staff
- Employee policies



Safe employee guide

Remote employee guide

e.g.



Uso del correo electrónico

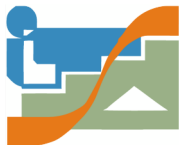
<https://www.incibe.es/empresas/herramientas/politicas>



Workplace protection regulations Documents

- Workplace protection manual
- Good practices manual
- Confidentiality agreement
- Reminders
- Training pills
- Cyber security training





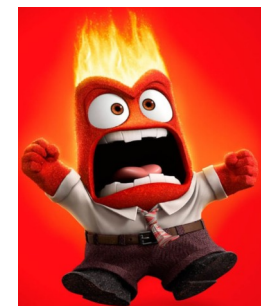
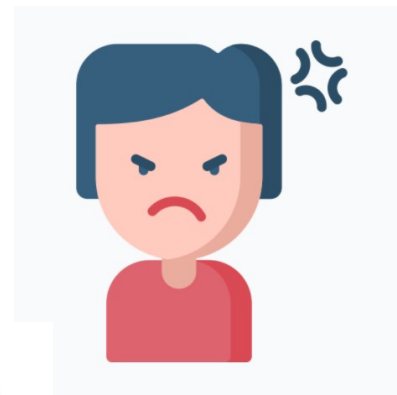
Workplace protection regulations

Insider



DLP

Data Loss Prevention



/2021/10/11/ser_malaga/

peor-enemigo-de-la-seguridad-i
nformatica



- General principles in cyber security
- Workplace protection regulations
- Training and awareness plan in terms of cyber security
- Training and awareness materials
- Internal compliance audits in the field of prevention



Cybersecurity training and awareness plan

Why make a plan?

In order to can prevent most incidents.

Objectives

The objectives of the plan should ensure that, At all times, employees know, understand and comply with the rules and measures protection adopted in matters of cybersecurity, warning them of the risks that may involve misuse of the devices and technological solutions at your fingertips.



Cybersecurity training and awareness plan

To achieve the objectives of this policy, it will be necessary to total commitment of the Management, which must be aware of that:

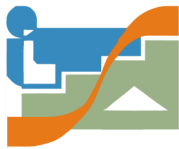
- Training will have to be continuous
- There will be reviewed periodically, to prevent incidents and adapt to the new technologies that will be used.



Cybersecurity training and awareness plan

It is important to highlight that certain positions in companies entail a great responsibility for information, with risks

There are potential risks about application of disciplinary measures in case of loss or disclosure of sensitive data, such as those that affect industrial property



Cybersecurity training and awareness plan

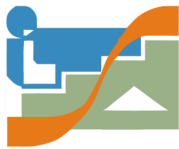
How to carry it out

- Establish a company security policy
- Adequately disseminate the security policy
- Specify a training plan
- Establish specific training programs
- Decide on a periodicity of the training
- Evaluate the learning obtained
- Promote a culture of information security (**all levels**)

[incibe.es - concienciacion-y-formacion.pdf](http://incibe.es-concienciacion-y-formacion.pdf)



- General principles in cyber security
- Workplace protection regulations
- Training and awareness plan in terms of cyber security
- **Training and awareness materials**
- Internal compliance audits in the field of prevention



Training and awareness materials

- Videos, training pills
- Informational posters
- Warning signs
- Good practices manual
- Talks
- Newsletters
- Webinars
- Courses (short)
- Training
- Testing (campaign)
- CISO reminders
- CTF's
- Hackaton

<https://derechodelared.com/documentacion-y-formacion-en-ciberseguridad/>



- General principles in cyber security
- Workplace protection regulations
- Training and awareness plan in terms of cyber security
- Training and awareness materials
- Internal compliance audits in the field of prevention



Internal audits of compliance in matters of prevention (of incidents)

Security audit of computer systems

An IT security audit includes the analysis and management of systems to identify and subsequently correct the various vulnerabilities that may appear in a comprehensive review

The results are detailed, archived and reported to those in charge who will have to establish preventive and reinforcement measures

The objectives of the audit: IT Systems

- ➔ Review the security of environments and systems
- ➔ Verify compliance with current regulations and legislation
- ➔ Prepare an **independent** report



Internal audits of compliance in matters of prevention (of incidents)

Qualities of an auditor

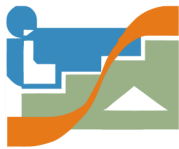
- Be impartial, sincere and honest.
- Be discreet and understand the concept of confidentiality.
- Keep an open mind to consider alternative ideas and points of view.
- Be diplomatic and tactful in dealing with different people.
- Be firm ...
- Have a high capacity for observation



Internal audits of compliance in matters of prevention (of incidents)

Audit policy

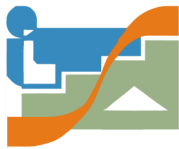
- Audits will be carried out periodically
- The periodicity of these reviews should be at least every six months.
- The audits will be repeated after the implementation of any significant change in the systems of the company.



Internal audits of compliance in matters of prevention (of incidents)

Type of audit

- **Internal security audit:** The security level of internal local and corporate networks is checked.
- **Perimeter security audits:** The perimeter of the local or corporate network, connected to public networks, is studied
- **Intrusion test:** Attempts are made to access the systems, to check the level of resistance to unwanted intrusion
- **Forensic analysis:** Post-incident analysis that tries to reconstruct how the system was penetrated while assessing the damage caused
- **Application code auditing:** Check for vulnerabilities such as SQL code injection



Internal audits of compliance in matters of prevention (of incidents)

- Phishing recognition test (<https://phishingquiz.withgoogle.com/?hl=es>)
- Phishing campaign (ethical) [gophish](#)
- Malware campaign (simulated)
- Backup compliance test
- Firewall compliance test
- Review of OS and Application versions
- Etc....

auditoria-interna-y-los-riesgos-de-ciberseguridad.pdf
<https://ctmaconsultores.com/que-es-una-auditoria-interna-de-ciberseguridad/>